

TEMA 1

INTRODUCCIÓN



“Este mundo no necesita un héroe;
necesita un profesional”



“S-82 NARCISO MONTURIOL” PROJECT v5.0

Por favor, informa de problemas con los materiales a redondojose@uniovi.es

Logo: @creative_vanesa (Instagram)



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo



ÍNDICE



Código ético



Introducción



Terminología básica



Tipos de malware



Introducción a las redes



Usuarios como objetivos

[< Ir al índice](#)



CÓDIGO ÉTICO

Los hackers NO son delincuentes y deben cumplir un código ético



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

● esta asignatura se divide en tres bloques

- **Conceptos generales:** Este tema + Tema 2
- **Seguridad defensiva:** Temas 3 – 5
- **Seguridad ofensiva:** Temas 6 – 7
 - Las técnicas y herramientas de este bloque pueden **deshabilitar, dañar o comprometer** objetivos reales
 - Y con eso, dañar a personas y los medios de vida de muchas de ellas
 - Usarlos contra objetivos **sin la debida autorización legal ES UN DELITO**
 - O **no cumplir las restricciones de uso** que has firmado (Hack the Box, Try to Hack me...)
 - Te van a capturar y procesar si la “lías parda”, no tengas duda
 - Sin embargo, debes saber **cómo operan los ciberdelincuentes** para defenderte de ellos...
 - *¿Vas a usar este conocimiento para ganarte la vida o para hacer tu vida miserable?*
- **Tu elección, tu responsabilidad, tu vida**

< Ir al índice



INTRODUCCIÓN

¡Zarpamos!



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

INTRODUCCIÓN: OBJETIVOS DE APRENDIZAJE



● Nuestro objetivo es...

- Conocer diferentes **conceptos** relacionados con la ciberseguridad
- Identificar los **riesgos** que pueden comprometer la ciberseguridad
- Conocer las **vulnerabilidades, amenazas**, técnicas de ataque y otros aspectos involucrados en la ciberseguridad
- Identificar diferentes tipos de **daños** que se les pueden causar a los sistemas

- **Un sistema informático es seguro cuando responde según lo previsto**

- Permite a cada usuario legítimo realizar todas las operaciones para las que está autorizado
- Evita que los usuarios realicen operaciones no autorizadas

- **Además, también garantiza a los usuarios legítimos tres cosas**

- **Confidencialidad**
- **Integridad**
- **Disponibilidad**
- Por lo general, se abrevian como **CIA** (por su acrónimo en inglés)

- **Entonces, los objetivos de la seguridad informática son**

- **Identificar vulnerabilidades**
- Crear y configurar **contramedidas** contra ellas
- **Evitar las amenazas existentes que explotan** estas vulnerabilidades



SEGURIDAD DE LOS SISTEMAS INFORMÁTICOS

- **esta asignatura comprende**

- Estudiar posibles **amenazas, riesgos...**
- Mejorar la seguridad de los sistemas informáticos (**hardening**)
- **Hacking ético y pentesting**

- **esta asignatura está relacionada fuertemente con varias otras**

- Omitirá varios temas de **administración de sistemas** para centrarse solo en los de **hardening**
 - Nuestra "asignatura hermano", Administración de Sistemas y Redes (**ASR**) se encarga de eso
- Omitirá el **análisis forense**
 - La optativa Informática Forense y Auditoría (**IFA**) se encarga de eso
- Solo mencionará la **gestión de riesgos**
 - La asignatura de Gestión de Proyectos (4º año) (**DPPI**) se encargará de eso
- Solo mencionará **temas relacionados con legislación**
 - La asignatura Aspectos Sociales, Legales, Éticos y Profesionales de la Ingeniería (4º año) (**ASLEPI**) se encargará de esto
- No se centrará en la **seguridad web**, solo en sus fundamentos
 - El Máster en Ingeniería Web (**MUINGEWEB**) en varias asignaturas, junto con varias microcredenciales de la Universidad de Oviedo, se encargan de ello

CLASIFICACIÓN GENERAL DE ATAQUES CONTRA DATOS Y SOFTWARE

● Confidencialidad

- Suplantación de identidad, captura de tráfico, acceso físico...

● Integridad

- Corrupción, manipulación...

● Disponibilidad

- Parar, eliminar, saturar ...



¡LOS DATOS SON UN OBJETIVO!

- Los datos deben estar protegidos
- Se deben crear copias adicionales (copias de seguridad)
 - Los procesos de restauración **también deben probarse**
- Los detalles y las políticas de copia de seguridad se ven en **ASR**
 - Para Windows / Linux

Fuente: <https://www.cybervista.net/what-every-executive-really-needs-to-know-about-cyber-part-1/>

What can happen to your data?

Data can be stolen

Impact on the confidentiality of your data

- Exploiting stolen data and selling it on the black market
- Using stolen data to gain unauthorized access to organizations
- Using stolen data for blackmail—organizational or individual—to manipulate your organization's decision making process
- Conducting espionage to steal confidential data and intellectual property, which can result in a hit to stock value or ruin an organization's reputation

Data can be corrupted

Impact on the integrity of your data

- Carrying out fraudulent transactions
- Altering and deleting data in transit by unauthorized entities
- Accidental alteration or deletion of data by authorized users

Data can be destroyed or locked down

Impact on the availability of your data

- Physical destruction of data or the systems holding the data
- Ransomware attacks that lock down your system have become a common method of attack among threat actors
- Denial of service (DOS/DDOS) attacks prevent your organization from carrying out business operations

SEGURIDAD, HOY

● La seguridad está evolucionando

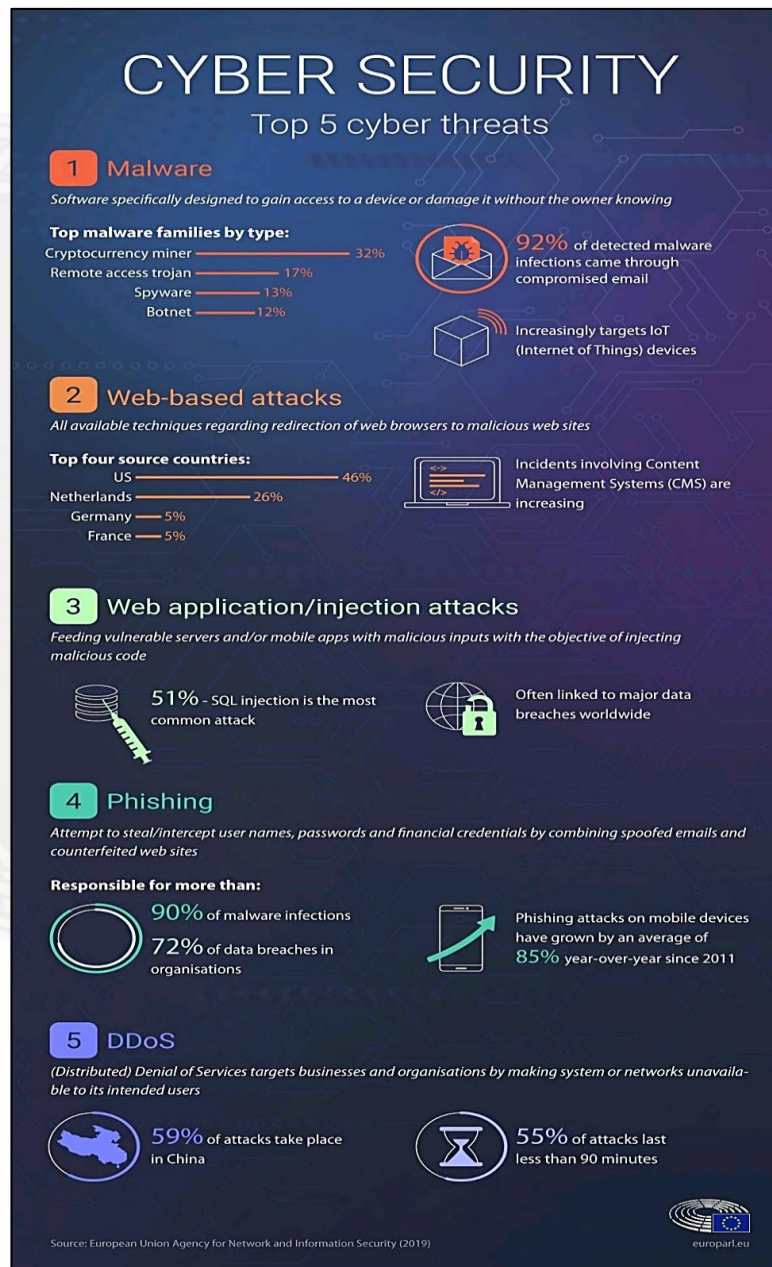
- Se necesitan muchos profesionales
- La desinformación, el malware y el phishing son las mayores amenazas

● Las amenazas se están potenciando

- Por OSINT (Open-Source INtelligence) (**Trabajos en grupo**)
- Por IA generativa

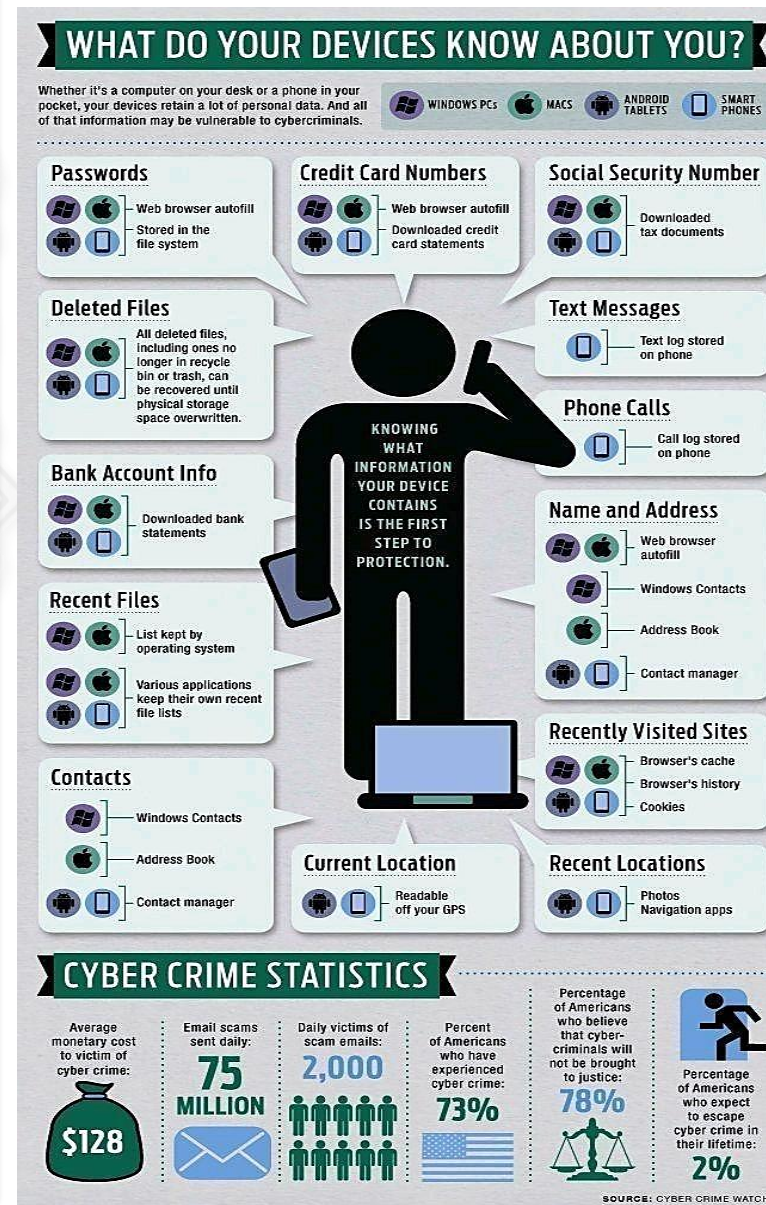
Fuente:

<https://m.facebook.com/comptechcyber/posts/>



SSI

Fuente: <https://www.cybercrimeswatch.com/>



LA SEGURIDAD DESDE LA PERSPECTIVA DEL PRINCIPIANTE



- Sabemos que la mayoría de vosotros no tienen experiencia en seguridad
- También sabemos que mucha gente cree que este mundo es algo difícil e inalcanzable

¡ESO ES FALSO!

- Vamos a abordarlo desde una perspectiva de “conocimiento cero”
 - Primero os daremos el conocimiento base necesario
 - Y más adelante, exploraremos temas cada vez más avanzados
 - Al final, podrás **defender tus sistemas y verificar su seguridad** adecuadamente
- Empecemos con **algunos conceptos básicos**

< Ir al índice

Tipos de malware >



TERMINOLOGÍA BÁSICA

Comprender conceptos básicos y "palabras de moda"



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

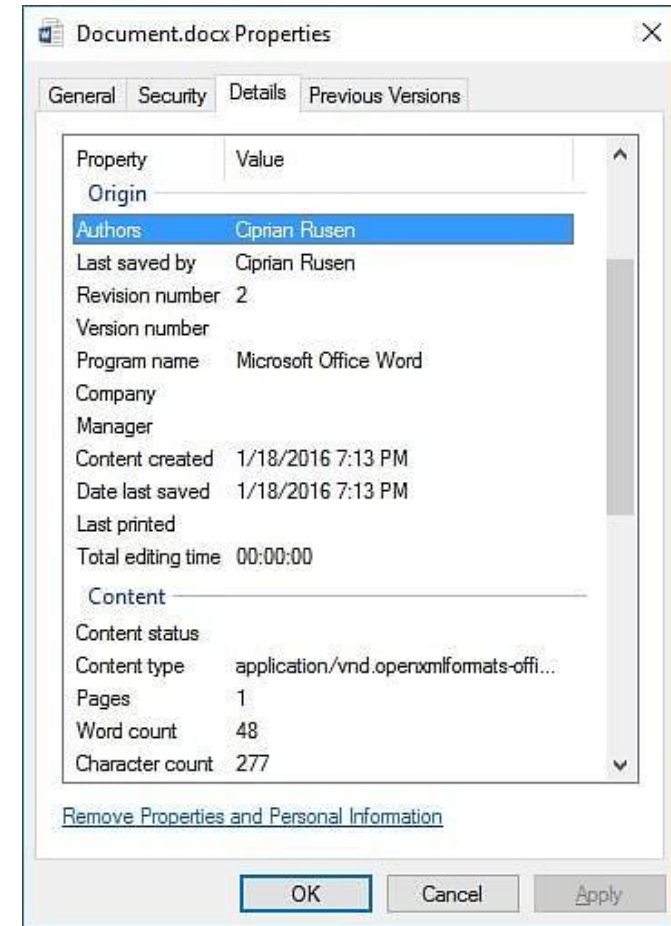
¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

- En este bloque aprenderás algunos conceptos básicos de seguridad
 - Qué son los **metadatos**
 - Qué es un **CVE** y qué representa
 - Qué es un **CVSS**
 - Los conceptos de **riesgo, ataque y daño**
 - Qué es un **control de seguridad**
 - Qué tipo de **atacantes** existen
 - Qué tipo de **equipos de seguridad** existen
 - Diferentes **tipos de malware** y lo que hacen



TERMINOLOGÍA BÁSICA: METADATOS

- **Datos que proporcionan información sobre otros datos**
 - Te ayuda a entender mejor una información o un archivo
- **Los metadatos de un archivo proporcionan información sobre un archivo en sí, en lugar de su contenido**
 - Autor, fecha de publicación, tamaño del archivo...
- **Ayuda a la búsqueda, gestión y clasificación de archivos**
 - Algunos programas **incluyen automáticamente metadatos** en los archivos que generan
 - *¿Ves un posible problema de seguridad/privacidad en eso?*



Metadatos típicos de un archivo de Windows. Fuente:

<https://www.digitalcitizen.life/what-file-s-metadata-and-how-edit-it/>

TERMINOLOGÍA BÁSICA: CONCEPTOS RELACIONADOS CON ATAQUES



- **Amenaza:** Personas, software, catástrofe natural...
- **Vulnerabilidad:** Puntos más débiles de un sistema
- **Payload** (carga útil)
- **Exploit:** Aprovechar una vulnerabilidad
 - ¡Se pueden encontrar muchos con ciertos motores de búsqueda!

Lifecycle of a Vulnerability



www.thecyphere.com

info@thecyphere.com

+44 (0) 333 050 9002

Los exploits no se pueden utilizar para siempre. Fuente:

<https://thecyphere.com/blog/vulnerability-threat-exploits-relationship/>

COMMON VULNERABILITIES AND EXPOSURES (CVE)



- Información de vulnerabilidades de seguridad conocidas públicamente de cualquier software

- Accesible de forma gratuita

- <https://cve.mitre.org/>
- <https://www.cvedetails.com/>
- ...

- Podemos hablar un idioma común

- "Esta aplicación es vulnerable al CVE-<año de descubrimiento>-<ID único>" (Ej.: CVE-2021-44228)
- ¿De qué sirven desde una perspectiva defensiva?
- ¿Y desde una ofensiva?

Fuente: https://www.cvedetails.com/vulnerability-list/vendor_id-23/product_id-22264/Debian-Apache2.html

Debian » Apache2 : Security Vulnerabilities										
CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9										
Sort Results By : CVE Number Descending CVE Number Ascending CVSS Score Descending Number Of Exploits Descending										
Copy Results Download Results										
#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score	Gained Access Level	Access	Complexity
1	CVE-2013-1048	264		+Priv	2013-03-06	2013-03-06	4.6	None	Local	Low
The Debian apache2ctl script in the apache2 package squeeze before 2.2.16-6+squeeze11, wheezy before 2.2.22-13, and sid before 2.2.22-13 for the Apache properly create the /var/lock/apache2 lock directory, which allows local users to gain privileges via an unspecified symlink attack.										
2	CVE-2012-0216			+Priv XSS +Info	2012-04-22	2017-08-28	4.4	None	Local	Medium
The default configuration of the apache2 package in Debian GNU/Linux squeeze before 2.2.16-6+squeeze7, wheezy before 2.2.22-4, and sid before 2.2.22-4, with example scripts under the doc/ URI, which might allow local users to conduct cross-site scripting (XSS) attacks, gain privileges, or obtain sensitive information from the Apache HTTP Server.										
Total number of vulnerabilities : 2 Page : 1 (This Page)										

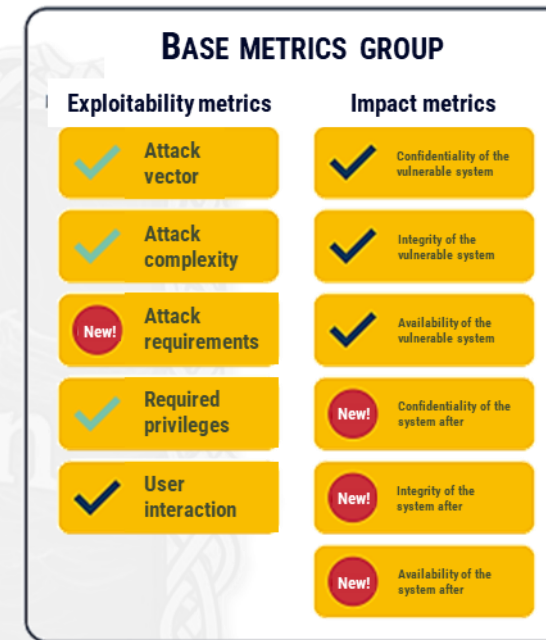
CVE-ID	
CVE-2020-8832	Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description	
The fix for the Linux kernel in Ubuntu 18.04 LTS for CVE-2019-14615 ("The Linux kernel did not properly clear data structures on context switch before 4.15.0-91.92, an attacker could use this vulnerability to expose sensitive information.	
References	
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.	
• CONFIRM:https://security.netapp.com/advisory/ntap-20200430-0004/ • MISC:https://bugs.launchpad.net/ubuntu/+source/linux/+bug/1862840 • UBUNTU:USN-4302-1 • URL:https://usn.ubuntu.com/usn/usn-4302-1	
Assigning CNA	
Canonical Ltd.	
Date Entry Created	
20200210	Disclaimer: The entry creation date may reflect when the CVE ID was allocated or reserved, and does not necessarily reflect when the vulnerability was updated in CVE.
Phase (Legacy)	
Assigned (20200210)	

Fuente : <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-8832>

CVSS (COMMON VULNERABILITY SCORING SYSTEM) 4.0

CVSS V4

- Por lo tanto, el CVE es como un glosario que clasifica las vulnerabilidades conocidas
 - Y lo que se sabe de ellas
- La gravedad de esas vulnerabilidades se puntúa con la puntuación CVSS
- Recientemente actualizado a la versión 4.0
 - Para hacer que un CVSS no sea solo una puntuación
 - **Incluye más métricas** que modelan mejor el tipo de vulnerabilidad, su **impacto**, lo necesario **para explotarla** (privilegios, interacción del usuario...), etc.
 - *¿Qué dirías que es un CVSS de una vulnerabilidad entonces?*
 - Además, **cómo afecta la vulnerabilidad a la CIA** vista anteriormente



El grupo de métricas CVSS para caracterizar la gravedad de un CVE.
Fuente:

<https://www.incibe.es/incibe-cert/blog/cvss-v40-avanzando-en-la-evaluacion-de-vulnerabilidades>

CVSS v4.0 calculator - PUBLIC PREVIEW

CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:A/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS v4.0 Score: 5.4 / Medium ⊕

Base Metrics ?

Exploitability Metrics

Attack Vector (AV):

Attack Complexity (AC):

Attack Requirements (AT):

Privileges Required (PR):

User Interaction (UI):

Vulnerable System Impact Metrics

Confidentiality (VC):

Integrity (VI):

Availability (VA):

TERMINOLOGÍA BÁSICA: RIESGOS

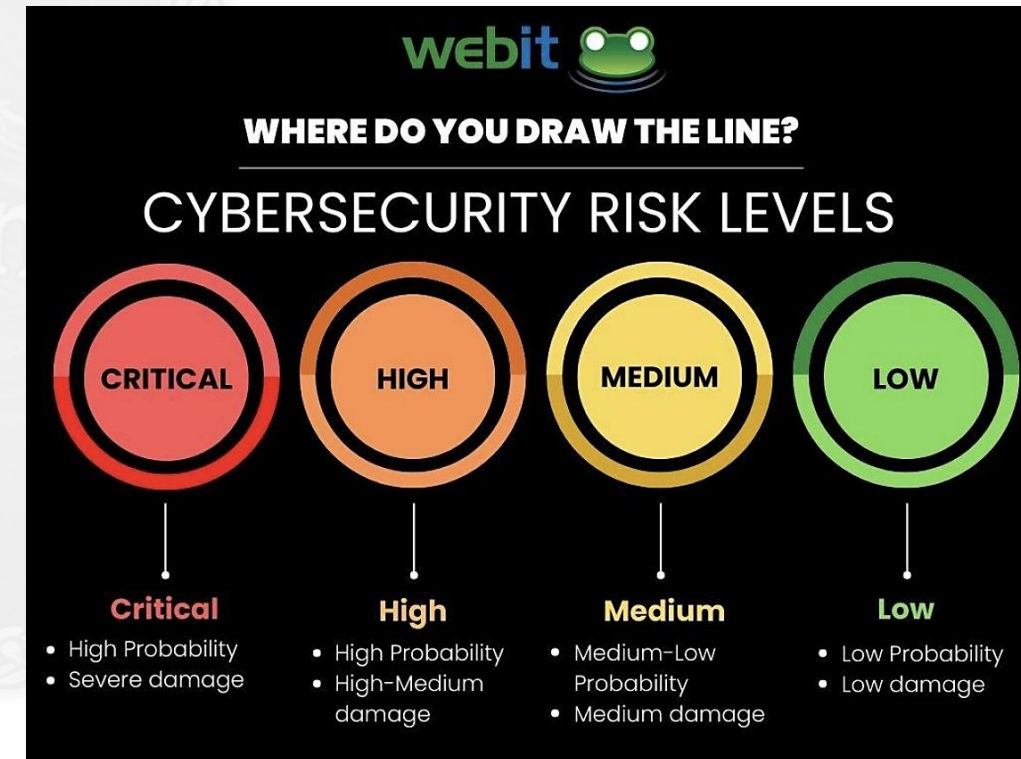
● Riesgo

- Resultado de *Amenaza x Vulnerabilidad x Valor del objetivo*

● Ataque

- Razón
- Método
- Oportunidad

● Daño



Los riesgos se clasifican en niveles (visto en DPPI).

Fuente: <https://www.webitservices.com/blog/cybersecurity-risk-levels/>

TERMINOLOGÍA BÁSICA: SEGURIDAD DEFENSIVA

● **Control (de Seguridad) o Contramedida:** Mecanismo de protección que mitiga o elimina un riesgo

- Cada control puede centrarse en la **prevención, mitigación, redirección, detección o recuperación** de ataques
- Los **estándares o políticas de seguridad** tienen sus propias **listas de controles (Tema 3)**
- Pueden ser **técnicos** (comandos de bajo nivel) u **organizacionales** (más abstracto, alto nivel)

Controles de seguridad técnicos (de bajo nivel). Fuente:

<https://www.impactmybiz.com/blog/cisv8-critical-security-controls/>

Description:

The Uncomplicated Firewall (ufw) is a frontend for iptables and is particularly well-suited for host-based firewalls. ufw provides a framework for managing netfilter, as well as a command-line interface for manipulating the firewall

Rationale:

A firewall utility is required to configure the Linux kernel's netfilter framework via the iptables or nftables back-end.

The Linux kernel's netfilter framework host-based firewall can protect against threats originating from within a corporate network to include malicious mobile code and poorly configured software on a host.

Note: Only one firewall utility should be installed and configured. **UFW** is dependent on the iptables package

Audit:

Run the following command to verify that Uncomplicated Firewall (UFW) is installed:

```
# dpkg-query -s ufw &>/dev/null && echo "ufw is installed"
ufw is installed
```

Remediation:

Run the following command to install Uncomplicated Firewall (UFW):

```
# apt install ufw
```

THE 18 CIS CONTROLS



Controles de seguridad organizacionales (de alto nivel).

Fuente: <https://www.impactmybiz.com/blog/cisv8-critical-security-controls/>

TERMINOLOGÍA BÁSICA: TIPOS DE ATACANTES (o "ADVERSARIOS")

- Script kiddies o n00bs (también conocidos como skiddies)
- Pentesters (**white hat hackers**)
- Crackers (**black hat hackers**)

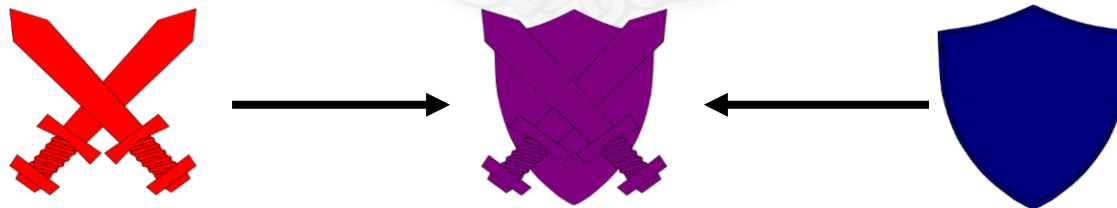
UN HACKER NO ES UN CRIMINAL

(A PESAR DE LO QUE DIGA LA PRENSA/PELICULAS)



TERMINOLOGÍA BÁSICA: EQUIPOS DE SEGURIDAD

- La naturaleza de las actividades de seguridad divide a los profesionales de seguridad en equipos
 - Red team
 - Blue team
 - Purple team
- Más información: <https://danielmiessler.com/study/red-blue-purple-teams/>





Tipos de malware

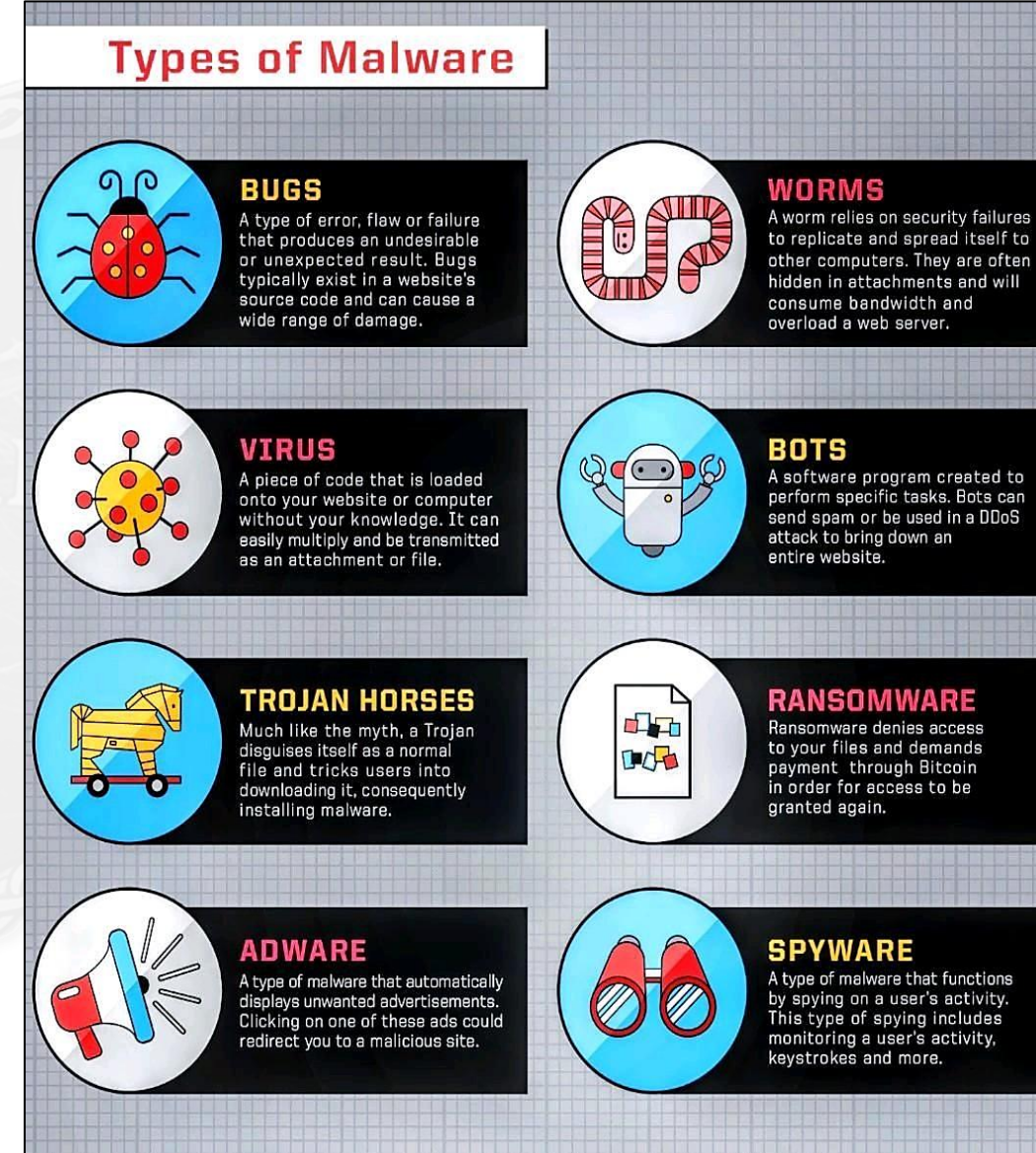
Tipos de programas creados para perjudicarte



MALWARE (MALICIOUS SOFTWARE)

- El software puede crearse para el bien o para mal
 - Entonces, *¿podrías crear un malware ahora mismo?*
- Algunos efectos dañinos comunes son
 - Causar fallos / manipulación o destrucción de datos
 - Robar información personal / privada
 - Ataques distribuidos / coordinados
 - Insertar anuncios (con efectos maliciosos, malvertising)
 - Extorsión / daño financiero / destrucción de datos
 - ...

Fuente: <https://m.facebook.com/viehgroupphotos/types-of-malwarebugs-worms-virus-bots-trojanhorse-ransomware-adware-spyware/2432740090357492/>



MALWARE QUE SE PROPAGA

● Por lo general, el malware se clasifica en

- Virus
- Gusanos
- Troyanos: Cuidado con las descargas ilegales / no fiables
 - Algunos son droppers
 - Suelen causar ataques a la cadena de suministro
- Spyware
- Keyloggers
- Adware
- Secuestradores de navegadores



Malware Type	Description	Delivery Methods	Payload/Functionality	Counter measures
Virus 	Infects files and spreads by attaching to executable code.	Email attachments, infected files, downloads	File corruption, data destruction, replication	Antivirus software, regular updates, user awareness
Worm 	Self-replicates and spreads independently across networks.	Email attachments, network vulnerabilities	Network congestion, data corruption, unauthorized access	Network security, patches, antivirus software
Trojan Horse 	Disguises itself as legitimate software to deceive users.	Email attachments, malicious downloads	Information theft, backdoor access, remote control	Security software, cautious browsing, user awareness
Spyware 	Monitors user activities and collects sensitive information.	Bundled with legitimate software, malicious websites	Keystroke logging, data theft, unwanted advertisements	Antispyware software, secure browsing habits, user education
Ransomware 	Encrypts files and demands payment for decryption keys.	Email attachments, malicious downloads	File encryption, ransom demands, data extortion	Data backups, security software, user education
Adware 	Displays unwanted advertisements to generate revenue.	Bundled with free software, malicious websites	Intrusive ads, browser toolbars, tracking cookies	Ad blockers, security software, cautious downloads
Rootkit 	Conceals malicious software to gain unauthorized access.	Exploits vulnerabilities, email attachments	Stealthy system access, backdoor installation, persistence	Rootkit detectors, regular system scans, secure configurations
Botnet 	Network of compromised computers controlled by a command server.	Exploits vulnerabilities, malicious downloads	Distributed denial-of-service (DDoS) attacks, spam distribution	Network monitoring, antivirus software, user education
Logic Bomb 	Triggers malicious actions based on a specific event or condition.	Inserted into software, triggered by specific event	Data corruption, system disruption, malicious actions	Regular audits, security monitoring, code reviews
Polymorphic Malware 	Evolves its code to evade detection by security software.	Email attachments, malicious downloads	Constantly changing code, encryption, self-modification	Heuristic analysis, behavior-based detection, regular updates
Fileless Malware 	Operates in memory without leaving a traditional file trace.	Exploits vulnerabilities, malicious scripts	Memory-based attacks, evades traditional file scans	Behavioral analysis, endpoint protection, user education

RANSOMWARE

- El tipo de malware más popular hoy día
- Debes comprender cómo funciona (fases de infección)
 - *¿Crees que recuperarás tus datos si pagas el rescate?*
- También existe el **Ransomware-as-a-Service (RaaS)**
- La solución más recomendable es **usar copias de seguridad no infectadas**
 - *¿Crees que los operadores de malware harán algo al respecto?*
- **Más información**
 - <https://www.osi.es/es/actualidad/avisos/ransomware>



Fuente: TrendMicro

RANSOMWARE



SSI

The Ransomware Kill Chain



During the *Reconnaissance* phase, the attacker collects as much information as possible: mailing lists, social media presence, potential vulnerabilities...

During the *Weaponization* phase, attackers prepare their malicious software. There is a plethora of techniques to disguise the payload in a benign-looking file, (pdf, word, excel...), or in a compromised or malicious website.



During the *Delivery* phase, the malicious payload (the dropper) is delivered to the intended target through an infected link to a file or site, an infected attachment, visiting infected websites (watering-hole, exploit kit or drive-by-download attacks) or malvertising.

During the *Exploitation* phase, existing vulnerabilities will be leveraged to deliver malicious code onto the system to get a better foothold.



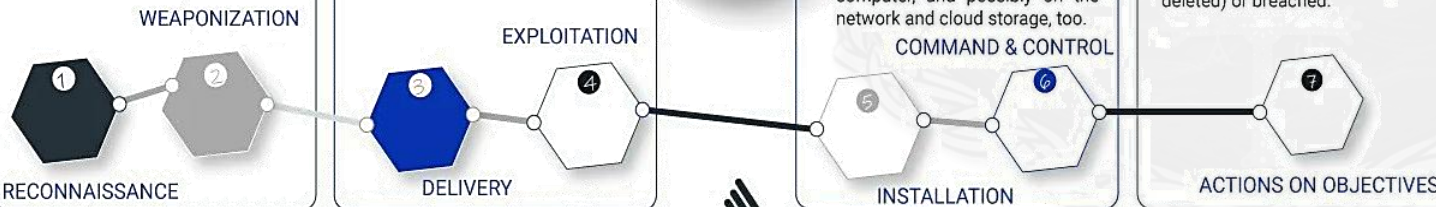
Once the dropper is on the victim's computer, the *Installation* process starts. Typically it connects to the *Command & Control* (C2) server to download key data (a malicious executable file, in some cases the encryption key...).

There are variants of ransomware that operate on a self-propagation basis and will attempt to infect system files and spread to other hosts. Then, the ransomware starts to encrypt files on the infected computer, and possibly on the network and cloud storage, too.



Now, following a successful installation, C2 establishment and encryption across the existing infrastructure (local hosts, network and cloud resources), we reach the *Actions on Objectives* phase. The ransomware displays a ransom message to the victim. Typically, the desktop wallpaper is used for this purpose.

Finally, the criminals expect the ransom to be paid in cryptocurrency in a wallet they own. If the victim does not pay, the data is either lost (encryption keys deleted) or breached.



Cyber Startup Observatory®



cyberstartupobservatory.com

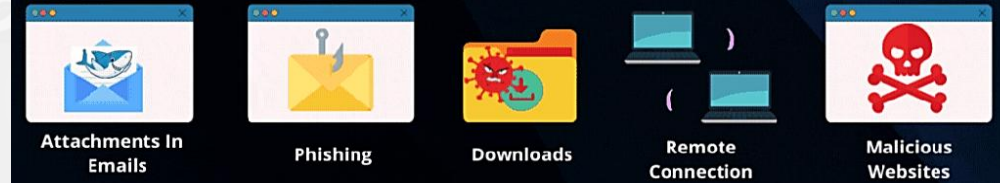
Malware and Ransomware

Cyber Writes
cyberwrites.com

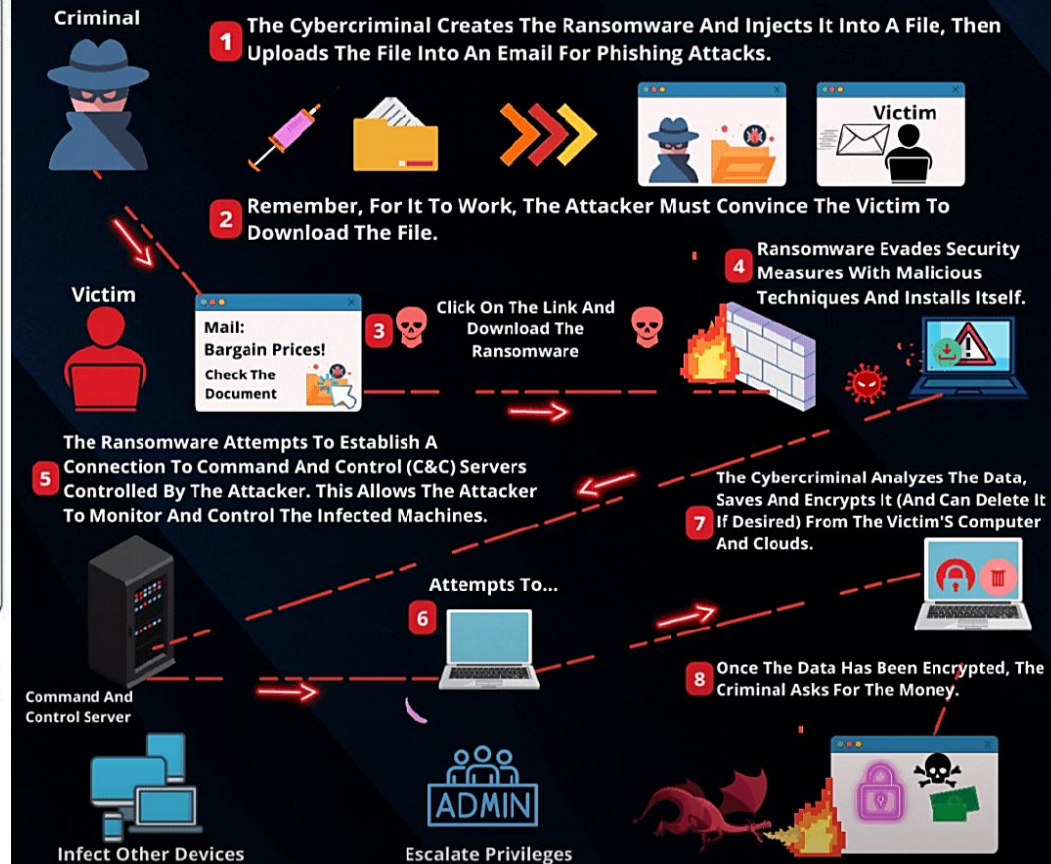
It Is A Type Of Malicious Software That Encrypts Files, Usually The User'S Office Files, And Extorts Money From The Affected Party In Exchange For A "Ransom" For The Affected Information.

How Does It Work?

It All Starts With The Infection Of The Computer By Means Of These Possible Attack Vectors:



Here Is An Example Of A Ransomware Attack:



MALWARE QUE USA PRIVILEGIOS ELEVADOS

● Otros conceptos populares relacionados con el malware son

- **Rootkits**

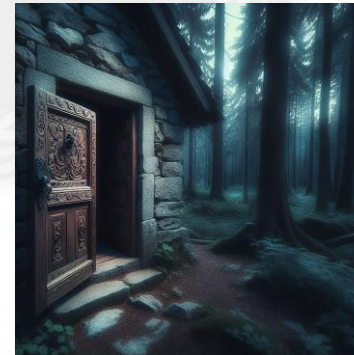
- *¿Qué tipo de software legal conoces que incluya este tipo de funcionalidades de "Gran Hermano"?*

- **Software fraudulento (rogue software)**

- **Crimeware**

- **Puertas traseras (backdoors)**

- *¿Qué crees que puede crear una puerta trasera maliciosa en un programa o sistema operativo?*
 - *¿Te imaginas una forma no maliciosa de tener una puerta trasera en un programa de software?*



Fake Antivirus Software Explained

Fake antivirus software scams are specifically designed to frighten web users.



1

You come across a malicious link or website containing fake antivirus software.



2

The fake antivirus software bombards you with pop-ups and alerts indicating you have a virus.



3

The fake antivirus software requests payment information to remove the phony viruses.



4

You lose your money to the scammer and risk infecting your computer with additional malware.

Fuente: <https://us.norton.com/blog/online-scams/what-is-a-fake-antivirus>

¿CREES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



● Puedes hacer lo siguiente

- *Comprender los conceptos de seguridad CIA en general*
- *Qué son los metadatos y qué usos podrían tener*
- *Saber qué hay en un CVE en general y por qué es importante en la seguridad*
- *Saber qué es el sistema de puntuación CVSS, qué tipo de elementos contiene y cómo interpretar una puntuación CVSS*
- *Comprender qué es un riesgo de seguridad y cómo se calcula*
- *Distinguir entre ataque y daño*
- *Comprender qué es un control de seguridad y su contenido relacionado con la prevención y respuesta a ataques*
- *Conocer la diferencia entre un script kiddie, un pentester y un cracker*
 - *Y, sobre todo, lo que NO es un hacker*
- *Conocer la diferencia entre un red team, un blue team, y un purple team*
- *Distinguir entre tipos de malware y lo que hacen: virus, gusanos, troyanos, spyware, keylogger, adware, secuestradores, ransomware, rootkit, software malicioso, crimeware y puerta trasera*
- *El “kill chain” del ransomware, cómo actúa y cómo compromete una infraestructura*



[< Ir al índice](#)



CONCEPTOS BÁSICOS DE REDES

¡No puedes hackear lo que no puedes ver!



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?



- **En este bloque, aprenderás**
 - Cómo se hace la **comunicación entre máquinas**
 - Conceptos básicos de...
 - **Puertos**
 - **Servicios**
 - **Protocolos de red**

¿CÓMO SE COMUNICAN LAS MÁQUINAS ENTRE SÍ?

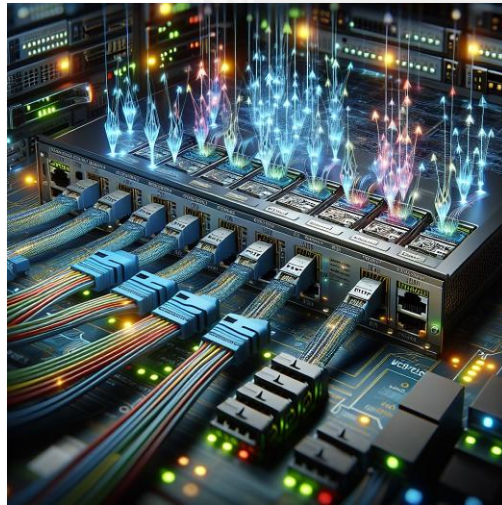
- En esta asignatura **NECESITAS** entender las redes IP
- Asegúrate de dominar estos conceptos de nuestra "asignatura hermana" **ASR** y/o **FCR**
 - Formato de direcciones **IPv4** e **IPv6**
 - Condiciones que permiten la **comunicación entre dispositivos** en una red IP típica
 - Direcciones **IPv4** válidas
 - Redes **LAN / WAN**
 - **Máscaras CIDR**
 - **Direcciones reservadas** en una red IP
 - **Rangos de direcciones IPv4** privadas y públicas
 - Y comandos básicos de **Linux**

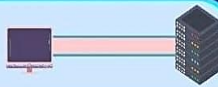
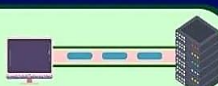
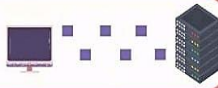
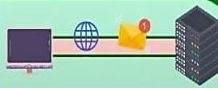


Fuente: <https://formatalent.com/asignaturas-de-m2m-machine-to-machine>

¿QUÉ ES UNA MÁQUINA EN UNA RED, VISTA DESDE FUERA?

- Una vez contactamos con una máquina, tenemos una **visión externa** de lo que ofrece a los usuarios
- Está compuesta por
 - **Puertos**, que tienen **servicios** que se comunican con clientes
 - Usando ciertos **protocolos de comunicación**
 - **Archivos** que pueden indicar a elementos ajenos que hagan (o no) ciertas cosas (Ej.: **robots.txt**)



Networking Protocols Explained			
PROTOCOL NAME		DESCRIPTION	DIAGRAM
HTTP	Hyper Text Transfer Protocol	Used by web browsers and servers to communicate and exchange	
HTTPS	Hyper Text Transfer Protocol Secure	An extension of HTTP that offers secure and encrypted communication	
FTP	File Transfer Protocol	Used to transfer files between a client and server	
TCP	Transmission Control Protocol	Delivers a stream of order bytes from one computer to another	
		 Cyber Writes	www.cyberwrites.com
IP	Internet Protocol	Addresses and routes packets of data sent between networked devices	
UDP	User Datagram Protocol	A simple and connectionless protocol that does not divide messages into packets and send them in order.	
SMTP	Simple Mail Transfer Protocol	Used to transmit emails across IP networks.	
SSH	Secure Shell	A cryptographic network protocol to secure data communication, remote command-line login, and remote command execution between two networked computers	

- **Un puerto completa el acceso a un servicio ofrecido por una máquina**
 - ¡Una misma máquina puede ofrecer muchos servicios! (**uno por puerto**)
 - La IP es la dirección de la máquina a la que nos conectamos
 - El puerto marca qué servicio (de todos los que ofrece la máquina) se utiliza en esa dirección IP
- **Hay 65.536 puertos diferentes posibles en una máquina**
 - Los primeros 1.024 se denominan generalmente "**puertos comunes**", reservados para servicios conocidos típicos
 - Ej.: 22 (**ssh**), 443 (**https**), etc.
 - Los números de puerto más utilizados aparecen en la siguiente diapositiva
 - "**Abrir un puerto**" significa que una máquina ofrece un servicio al exterior
 - Ej.: servidor web, servidor de Minecraft...
 - *¿Cómo puedes abrir un puerto en tu PC si el router es el que se conecta a la red externa y tú solo te conectas al router?*

SOBRE LOS PUERTOS...

- Los puertos > 1024 "normalmente" contienen los servicios de la imagen
 - Pero a diferencia de los reservados, **no es obligatorio**
- Los puertos y los servicios a la escucha se pueden inspeccionar usando **nmap**
 - <https://nmap.org/>
- Los puertos pueden ser bloqueados / restringidos configurando el firewall
 - Lo veremos en el **Tema 5**

COMMON PORTS

TCP/UDP Port Numbers			
7 Echo	554 RTSP	2745 Bagle.H	6891-6901 Windows Live
19 Chargen	546-547 DHCPv6	2967 Symantec AV	6970 Quicktime
20-21 FTP	560 rmonitor	3050 Interbase DB	7212 GhostSurf
22 SSH/SCP	563 NNTP over SSL	3074 XBOX Live	7648-7649 CU-SeeMe
23 Telnet	587 SMTP	3124 HTTP Proxy	8000 Internet Radio
25 SMTP	591 FileMaker	3127 MyDoom	8080 HTTP Proxy
42 WINS Replication	593 Microsoft DCOM	3128 HTTP Proxy	8086-8087 Kaspersky AV
43 WHOIS	631 Internet Printing	3222 GLBP	8118 Privoxy
49 TACACS	636 LDAP over SSL	3260 iSCSI Target	8200 VMware Server
53 DNS	639 MSDP (PIM)	3306 MySQL	8500 Adobe ColdFusion
67-68 DHCP/BOOTP	646 LDP (MPLS)	3389 Terminal Server	8767 TeamSpeak
69 TFTP	691 MS Exchange	3689 iTunes	8866 Bagle.B
70 Gopher	860 iSCSI	3690 Subversion	9100 HP JetDirect
79 Finger	873 rsync	3724 World of Warcraft	9101-9103 Bacula
80 HTTP	902 VMware Server	3784-3785 Ventrilo	9119 MxIt
88 Kerberos	989-990 FTP over SSL	4333 mSQL	9800 WebDAV
102 MS Exchange	993 IMAP4 over SSL	4444 Blaster	9898 Dabber
110 POP3	995 POP3 over SSL	4664 Google Desktop	9988 Rbot/Spybot
113 Ident	1025 Microsoft RPC	4672 eMule	9999 Urchin
119 NNTP (Usenet)	1026-1029 Windows Messenger	4899 Radmin	10000 Webmin
123 NTP	1080 SOCKS Proxy	5000 UPnP	10000 BackupExec
135 Microsoft RPC	1080 MyDoom	5001 Slingbox	10113-10116 NetIQ
137-139 NetBIOS	1194 OpenVPN	5001 iperf	11371 OpenPGP
143 IMAP4	1214 Kazaa	5004-5005 RTP	12035-12036 Second Life
161-162 SNMP	1241 Nessus	5050 Yahoo! Messenger	12345 NetBus
177 XDMCP	1311 Dell OpenManage	5060 SIP	13720-13721 NetBackup
179 BGP	1337 WASTE	5190 AIM/ICQ	14567 Battlefield
201 AppleTalk	1433-1434 Microsoft SQL	5222-5223 XMPP/Jabber	15118 Dpnet/Oddbob
264 BGMP	1512 WINS	5432 PostgreSQL	19226 AdminSecure
318 TSP	1589 Cisco VQP	5500 VNC Server	19638 Ensim
381-383 HP Openview	1701 L2TP	5554 Sasser	20000 Usermin
389 LDAP	1723 MS PPTP	5631-5632 pcAnywhere	24800 Synergy
411-412 Direct Connect	1725 Steam	5800 VNC over HTTP	25999 Xfire
443 HTTP over SSL	1741 CiscoWorks 2000	5900+ VNC Server	27015 Half-Life
445 Microsoft DS	1755 MS Media Server	6000-6001 X11	27374 Sub7
464 Kerberos	1812-1813 RADIUS	6112 Battle.net	28960 Call of Duty
465 SMTP over SSL	1863 MSN	6129 DameWare	31337 Back Orifice
497 Retrospect	1985 Cisco HSRP	6257 WinMX	33434+ traceroute
500 ISAKMP	2000 Cisco SCCP	6346-6347 Gnutella	Legend
512 rexec	2002 Cisco ACS	6500 GameSpy Arcade	Chat
513 rlogin	2049 NFS	6566 SANE	Encrypted
514 syslog	2082-2083 cPanel	6588 AnalogX	Gaming
515 LPD/LPR	2100 Oracle XDB	6665-6669 IRC	Malicious
520 RIP	2222 DirectAdmin	6679/6697 IRC over SSL	Peer to Peer
521 RIPng (IPv6)	2302 Halo	6699 Napster	Streaming
540 UUCP	2483-2484 Oracle DB	6881-6999 BitTorrent	

IANA port assignments published at <http://www.iana.org/assignments/port-numbers>



- **Programas que se ejecutan asociados a un puerto de red**
- **Estos programas se ejecutan en la máquina de destino y...**
 - Esperan las conexiones entrantes de los clientes
 - Cuando un cliente se conecta a ellos (y usa **el protocolo de comunicación adecuado**) el servicio **procesa** la solicitud del cliente
 - Finalmente, **envía una respuesta**
- **De esta manera, cualquier máquina puede dar servicio a otras máquinas**
- **¡Y esta es la base de las comunicaciones de las máquinas hoy en día! 😊**
- ***¿Alguna vez organizaste un juego multijugador en tu PC? ¿Es eso un servicio?***

¿CREES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



● Puedes hacer lo siguiente

- *Entender que, dentro de una misma red, las IP identifican diferentes máquinas y que, por lo tanto, no puede haber dos máquinas con la misma IP*
- *Asegurarte de que recuerdas y entiendes los siguientes conceptos de ASR*
 - *Comprender el concepto de LAN*
 - *Conoces cómo es IPv4 y su estructura*
 - *Y por qué solo pueden estar compuestos por números del 0 al 255*
 - *El concepto de mascara CIDR y para qué sirve*
 - *Así como la técnica que se utiliza para saber si una IP pertenece a una determinada máscara CIDR*
 - *Para qué sirven las dos direcciones IP típicamente reservadas en una red LAN*
 - *Para qué se creó IPv6 y su estructura general*
- *La relación entre puertos, servicios y protocolos*
- *Cómo puedes hospedar servicios para otras personas/máquinas*

● ¿Problemas para entender las redes? Puedes probar otro enfoque para explicarlos con la F-83 “Numancia”

- https://github.com/jose-r-lopez/Formacion_-Seguridad_Joven/blob/main/F83_Numancia/F-83%20Numancia.%20Ataque.pdf



< Ir al índice



USUARIOS COMO OBJETIVOS

Ataques dirigidos a humanos



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

● En este bloque aprenderás

- Por qué lo que haces mientras navegas, tus gustos, tus preferencias, etc. (en definitiva, tu privacidad) **son moneda de cambio**
- Qué navegadores son **más respetuosos con la privacidad**
- Los conceptos de spam, phishing, hoax, watering hole, drive-by download, y APT
- Qué es **OSINT** como concepto



PRIVACIDAD

- **Tu historial de navegación, comportamiento, características físicas y sociales... es dinero**
 - Para **empresas de publicidad dirigida**
 - Para **entrenar modelos de IA generativa**
- **No pagas la mayoría de los servicios directamente**
 - Tus datos de comportamiento son el pago
 - **Si un servicio es "gratuito", ¡tus datos son el pago!**
- **Tus datos se recopilan en muchos lugares**
 - Apps de redes sociales, webs, tiendas... y navegadores
 - Y se recopilan por **data brokers** para hacerte un **“perfil completo”** desde todas esas fuentes
 - <https://privacytests.org/>

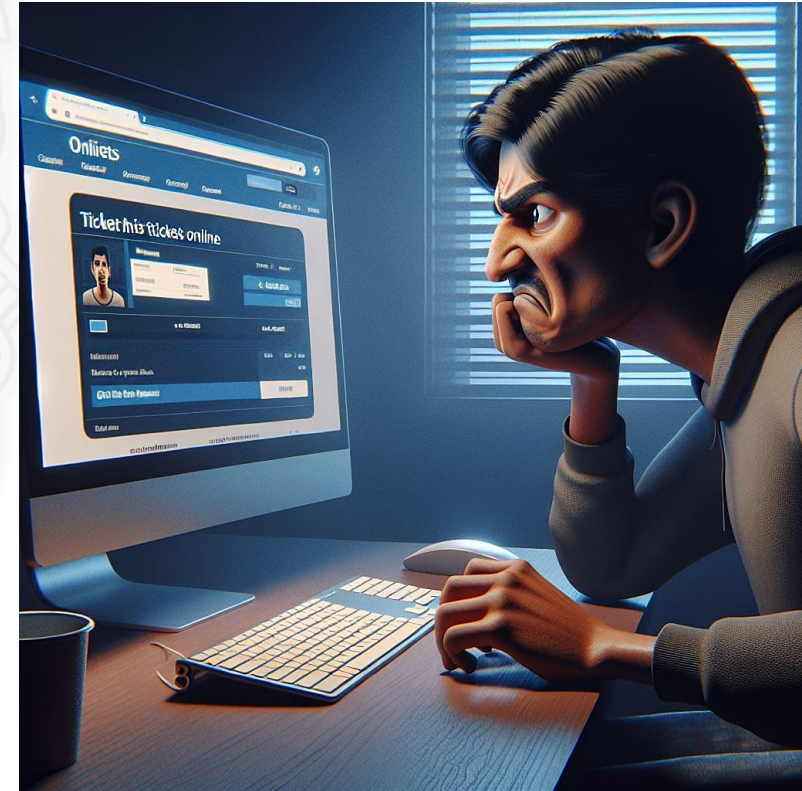
clarío.

The companies that know most about you

#	Company	% of personal data collected	Email	Name	Age	Gender/Sex	Sexual Orientation	Marital Status	Race	Religious Belief	Live Location	Home Address	Employment Status	Job Title	Pet/Animal Ownership	Mobile Number	Landline Number	Type of Phone/Device	Hobbies	Interests	Height	Weight	Next of Kin	Mother's Maiden Name	Current Employers	Past Employers	Bank Account Details	Salary	Social Profile (Friends)	Social Profile (Hobbies)	Social Profile (Interests)	Country of Birth	Allergies/Intolerances	Health & Lifestyle Info
1	 Facebook	70.59%	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•	•
2	 Instagram	58.82%	•	•	•	•					•	•	•	•	•	•	•	•	•	•	•	•		•	•			•	•	•	•	•	•	•
3	 Tinder	55.88%	•	•	•	•	•				•	•	•	•	•	•	•	•	•	•	•					•			•	•	•	•	•	•
4	 Grindr	52.94%	•	•	•	•	•																											
5	 Uber	52.94%	•	•	•	•					•	•	•	•	•	•	•	•	•	•	•				•	•			•	•	•	•	•	•
6	 Strava	41.18%	•	•	•	•					•	•			•	•	•	•			•	•				•			•	•	•	•	•	•
7	 Tesco	38.24%	•	•	•	•	•				•					•	•	•	•							•			•	•	•	•	•	•
8	 Spotify	35.29%	•	•	•						•					•	•	•	•	•	•					•			•	•	•	•	•	•
9	 MyFitnessPal	35.29%	•	•	•											•	•	•	•		•					•								•
10	 Jet2	35.29%	•	•	•	•	•	•			•				•	•	•	•	•	•	•					•								•
11	 Credit Karma	32.35%	•	•	•								•	•		•	•	•	•		•	•				•	•							
12	 Lidl Plus	32.35%	•	•	•						•	•			•	•	•	•	•							•								•
13	 Netflix	26.47%	•	•	•						•					•	•	•	•	•	•					•								
14	 Nike	26.47%	•	•	•	•					•					•	•	•	•		•	•				•								
15	 Asos	26.47%	•	•	•						•					•	•	•	•		•	•				•								
16	 Depop	26.47%	•	•	•						•					•	•	•	•		•	•				•								
17	 Ryanair	26.47%	•	•	•						•					•	•	•	•							•								•
18	 Ocado	26.47%	•	•	•											•	•	•	•							•								•
19	 Airbnb	26.47%	•	•	•	•					•			•	•	•	•	•	•							•								
20	 American Airlines	26.47%	•	•	•						•					•	•	•	•							•								•
21	 Ikea	23.53%	•	•	•						•					•	•	•	•	•	•					•								
22	 Trainline	23.53%	•	•	•						•	•				•	•	•	•							•								
23	 Amazon	23.53%	•	•	•						•	•				•	•	•	•							•								
24	 PayPal	23.53%	•	•	•						•					•	•	•	•						•	•								
25	 eBay	23.53%	•	•	•						•					•	•	•	•							•								
26	 Walmart	23.53%	•	•	•	•					•				•	•	•	•								•								
27	 Deliveroo	20.59%	•	•							•	•				•	•	•	•							•								•
28	 Twitter	20.59%	•	•	•	•					•							•	•															•
29	 NHS COVID-19	20.59%	•	•	•						•	•						•	•															•
30	 SlimmingWorld	20.59%		•	•	•												•	•	•	•													•
31	 Google Maps	20.59%	•	•	•						•	•					•	•	•					•										•
32	 CVS Pharmacy	20.59%	•	•	•	•					•					•									•									
33	 Amtrak	20.59%	•	•	•						•	•				•										•								
34	 Sleepcycle	20.59%	•	•	•	•												•	•	•	•					•								
35	 JustEat	17.65%	•	•							•							•	•							•								
36	 Offerup	17.65%	•	•							•	•				•										•								
37	Doordash	17.65%	•	•							•	•				•										•								
38	McDonalds (USA)	14.71%	•	•							•					•										•								
39	TikTok	14.71%	•	•	•													•	•															
40	Protect Scotland	14.71%		•							•	•						•	•															•
41	CoStar	14.71%		•	•											•	•	•	•															•
42	Bet365 USA	14.71%	•	•	•						•					•																		
43	Wetherspoon	14.71%	•	•							•							•	•							•								
44	Skybet	11.76%	•	•	•																					•								
45	Flo Period Tracker	11.76%	•	•														•	•															•
48	Whatsapp	11.76%	•	•												•																		
47	Facetune	5.88%	•															•	•															
48	Pornhub	5.88%																•	•															

● Correo electrónico fraudulento/no deseado enviado masivamente con múltiples objetivos

- Que el usuario acceda a sitios sospechosos
- Estafas
- Propaga **malware**
- Difunde campañas de **phishing**
- ...



PHISHING / SPEAR PHISHING

- **Mensajes maliciosos (correo electrónico, aplicaciones de mensajería...) que**
 - Su fuente **parece** ser legítima (banco, empresa...)
 - Se crean con **finés engañosos**
 - **Robar** credenciales, información privada o comprometedor
 - **Descargar** malware (cualquier tipo)
- **Se está volviendo más sofisticado**
 - Usando las capacidades de la IA moderna
 - Añadiéndoles datos falsos pero realistas (OSINT, **Trabajo en grupo**)
- **Se está volviendo más específico**
 - Spear phishing
 - Whaling
- **La prevención requiere una formación específica**
 - Te regalamos una asignatura específica para eso (ver más adelante)
 - **Pero NO ES PARTE de la evaluación de esta asignatura**



OTROS ATAQUES A USUARIOS

● Debes entender otros ataques dirigidos a los usuarios

- Robo de credenciales
- Bulos (Hoax)
 - Sitios web como MalditoBulo (<https://maldita.es/malditobulo/>) pueden ayudarnos a descubrir algunos de ellos
 - Evolucionaron hacia la **desinformación** mucho más peligrosa
 - ¿Quieres saber más? Mira el trabajo de José Manuel Redondo publicado por el INCIBE
 - <https://www.incibe.es/ed2026/materiales/de-la-seguridad-al-exito-la-ia-generativa-nicho-para-el-emprendimiento>
- Watering hole
 - https://en.wikipedia.org/wiki/Watering_hole_attack
- Drive-by download (aka Automatic downloads)
 - https://en.wikipedia.org/wiki/Drive-by_download
- Advanced Persistent Threat (APT)



OPEN-SOURCE INTELLIGENCE (OSINT)

- **Conjunto de datos recopilados de fuentes públicas**

- Se usan en el estudio de un objetivo (**persona** o **sistema**)
- Medios de comunicación, Internet, datos públicos gubernamentales, publicaciones profesionales y académicas, datos comerciales, otros trabajos...

- **Según el Departamento de Defensa de EE. UU.**

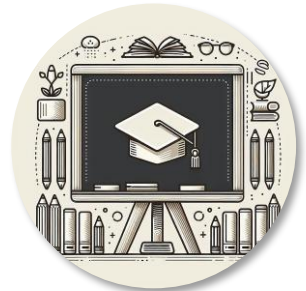
- *"Información disponible públicamente que se recopila, explota y distribuye de forma predeterminada a una audiencia adecuada, con la intención de cumplir con un requisito de investigación específico"*

- **Por lo tanto, es un conjunto de información pública **legalmente accesible****

- Que se puede usar para averiguar ciertos datos, rutinas, estructuras, etc. de un determinado colectivo / persona / empresa

- **Existen herramientas OSINT especializadas para cada fuente de datos**

- Ver el **Seminario 1** y los **Trabajos en Grupo**



PREVENCIÓN: FORMACIÓN DE USUARIOS



- **La mejor contramedida es la capacitación del usuario con materiales adecuados**
 - Tanto en el ámbito personal como en el profesional
- **Materiales de entrenamiento de ejemplo**
 - **INCIBE** dispone de muchos para diferentes perfiles de usuario
 - Por ejemplo: "**Experiencia senior**" (usuarios no experimentados):
 - <https://www.incibe.es/ciudadania/experiencia-senior>
 - Como parte de nuestra iniciativa "Armada Asturiana" contamos con
 - El proyecto **P-48 "Intrépido"**, de regalo
<https://uniovix.uniovi.es/course/view.php?id=77>
 - Varios **materiales de formación gratuitos** para todos los perfiles
 - https://github.com/jose-r-lopez/Formacion_-Seguridad_Joven/wiki
 - Además, **un podcast orientado a la prevención del fraude** en YouTube
 - https://www.youtube.com/channel/UCrB3D_97pYWIfBZBmCJiYzw

¡Sé un "campeón de la seguridad"!



¿CREES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



● Puedes hacer lo siguiente

- *Entender que, si un servicio es gratuito, tus datos son el pago*
 - *Y esos datos se usan para mostrarte anuncios más relevantes para tus gustos (supuestamente)*
 - *Y que, por supuesto, esta es una forma muy lucrativa de financiación para las empresas*
- *Comprender que, incluso si un servicio no es gratis, aún podrían usar tus datos para lucrarse*
- *Comprender qué es el spam, en general*
- *Cómo distinguir el phishing del spear phishing*
- *Qué es un hoax y para qué se puede utilizar*
- *Qué es un watering hole y por qué se considera un ataque dirigido a un colectivo*
- *Qué es una drive-by download y por qué son peligrosas*
- *Qué es una APT y, por lo general, qué tipo de intenciones tienen*
- *Qué es OSINT y cómo, gracias a él, todo lo que alguien publica en Internet puede ser utilizado en su contra de alguna manera*

● ¿Interesado en más información sobre la prevención del fraude?

- Lee los **F-31 “Descubierta”**, **M-31 “Segura”**, **P-74 “Atalaya”**, y el **“Nautilus”**
- https://github.com/jose-r-lopez/Formacion_-Seguridad_Joven/wiki



TEMA 1



INTRODUCCIÓN



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo